

Cómo protegemos los identificadores en CMAT-research

Explicación para personal administrativo

Centro de Aprendizaje de Matemáticas (CMAT)

1. La idea en una frase

En las bases utilizadas para investigación no necesitamos saber que un estudiante es “175199”; necesitamos saber que varias observaciones pertenecen *al mismo estudiante*. Por eso reemplazamos el ID original por una etiqueta criptográfica estable, por ejemplo

175199 $\longrightarrow$ `stu_c504a778e1e4b331721d7c88f22c65e0`.

El valor de la derecha permite reconocer a la misma persona en diferentes tablas, pero no contiene el número 175199 de una forma que pueda simplemente leerse o descifrarse.

2. ¿Es un mecanismo confiable?

Sí. El mecanismo se llama **HMAC-SHA256** y no fue inventado para este proyecto. Es una construcción criptográfica estandarizada que se utiliza en servicios tecnológicos de uso cotidiano para comprobar que información o solicitudes provienen de una fuente legítima y no fueron modificadas.

Para dimensionarlo con ejemplos conocidos:

- **Amazon (AWS)** utiliza HMAC-SHA256 en su sistema Signature Version 4 para autenticar solicitudes a sus servicios en la nube;
- **Google Cloud** admite llaves HMAC y firmas HMAC para ciertos mecanismos de acceso e interoperabilidad de Cloud Storage;
- **GitHub** recomienda HMAC-SHA256 para verificar que los avisos automáticos enviados por sus webhooks realmente provienen de GitHub;
- **Slack** firma solicitudes con un secreto y HMAC-SHA256 para que una aplicación pueda verificar que el mensaje realmente fue enviado por Slack;
- **Shopify** incluye una firma HMAC-SHA256 en sus webhooks HTTPS para verificar que una notificación proviene de Shopify;
- **Zoom** utiliza HMAC-SHA256 para verificar la autenticidad de eventos enviados mediante webhooks.

Estas empresas no usan HMAC-SHA256 necesariamente para ocultar matrículas o IDs de estudiantes; lo emplean en problemas distintos de seguridad. La comparación importante es que **CMAT utiliza la misma primitiva criptográfica básica —HMAC con SHA-256— que plataformas globales utilizan cuando necesitan que un valor dependa de una llave secreta y no pueda reproducirse correctamente sin conocerla.**

En otras palabras, no estamos sustituyendo una matrícula mediante una regla casera como “sumarle un número”, “cambiar los dígitos” o aplicar un hash simple. Estamos utilizando un mecanismo criptográfico estándar, público y ampliamente analizado, cuya seguridad depende de una llave secreta generada aleatoriamente.

3. Un ejemplo sencillo

Tomemos como ejemplo el ID

175199.

Antes de procesarlo, el programa añade una pequeña etiqueta que indica que se trata de un estudiante:

stu:175199.

Después lo combina con una **llave secreta muy larga**. Para esta explicación usaremos una llave ficticia:

7b41e7a1c76f6b50f58a0c628a3f0e8daed7ad4f6dd6c7e97ad31e8f8ad1e933

Esa no es la llave real del proyecto. La llave real debe permanecer separada de las bases y del repositorio.

El algoritmo mezcla el texto stu:175199 con esa llave y lo pasa por SHA-256 en una construcción especial llamada HMAC. El resultado completo de nuestro ejemplo sería

c504a778e1e4b331721d7c88f22c65e0008707cede372864628d04a20bbe27fb

Para los datos de investigación guardamos una parte suficientemente grande de ese resultado y obtenemos

stu_c504a778e1e4b331721d7c88f22c65e0.

Si mañana vuelve a aparecer el ID 175199, usando la misma llave obtendremos exactamente el mismo pseudónimo. Por eso podemos estudiar, por ejemplo, varias asesorías de un mismo estudiante a lo largo del tiempo sin conservar su matrícula original en la base de investigación.

4. ¿Por qué la llave es tan larga?

La llave recomendada contiene 64 caracteres hexadecimales. Esos 64 caracteres representan **256 bits de aleatoriedad**, lo cual significa que existen aproximadamente

$$2^{256} \approx 1.16 \times 10^{77}$$

llaves diferentes posibles.

Para dar una idea de la escala, incluso una máquina hipotética capaz de probar un trillón de trillones de llaves por segundo, es decir, 10^{18} intentos cada segundo, necesitaría del orden de

$$10^{51} \text{ años}$$

para recorrer el espacio completo. La protección no proviene simplemente de que la llave “se vea larga”, sino de que se genera de manera aleatoria y se mantiene secreta.

5. ¿Se puede descifrar?

No en el sentido habitual de la palabra. **HMAC no es un cifrado**, así que no existe una operación de “descifrar” que tome `stu_...` y devuelva automáticamente 175199.

La forma sencilla de pensarlo es la siguiente. El algoritmo funciona como una máquina que recibe dos cosas:

$$\text{ID} + \text{llave secreta} \longrightarrow \text{pseudónimo}.$$

La máquina funciona muy bien hacia adelante, pero el resultado no contiene una copia escondida del ID que pueda extraerse hacia atrás.

Sin la llave, probar cuál era el ID original es computacionalmente impracticable. Si alguien robara la llave, sin embargo, podría tomar una lista de IDs posibles, calcular sus pseudónimos y compararlos. Por eso **la llave se guarda aparte y nunca debe viajar junto con los datos**.

6. Una analogía

Puede imaginarse una máquina de sellos. Cada persona introduce su ID y la máquina utiliza un molde secreto enorme para producir un sello único. El mismo ID siempre produce el mismo sello, por lo que podemos reconocer que dos registros corresponden a la misma persona; sin conocer el molde secreto, observar el sello no permite reconstruir de manera práctica el número que entró.

La analogía tiene un límite importante: aunque ocultemos el ID, otros datos pueden revelar información sobre una persona. Si una fila incluye una combinación muy particular de carrera, fecha, materia, calificación y trayectoria, esos datos pueden actuar como pistas.

7. Por eso hablamos de pseudonimización, no de anonimato absoluto

La protección utilizada en CMAT-research tiene dos partes. Primero, los identificadores directos se sustituyen mediante HMAC-SHA256 y la llave secreta permanece fuera de la base; segundo, los microdatos siguen sujetos a control de acceso porque otras variables podrían funcionar como cuasi-identificadores.

Por tanto, la afirmación correcta no es “estos datos son imposibles de identificar bajo cualquier circunstancia”, sino:

Los identificadores institucionales se sustituyen mediante una primitiva criptográfica estándar y ampliamente utilizada; sin la llave secreta, el pseudónimo no puede descifrarse ni vincularse eficientemente con el ID original únicamente a partir de ese valor.

8. Resumen visual

$175199 + \text{llave secreta de 256 bits} \xrightarrow{\text{HMAC-SHA256}} \text{stu_c504a778e1e4b331721d7c88f22c65e0}$

La misma persona conserva el mismo pseudónimo para fines de análisis, mientras que su identificador institucional directo permanece fuera de la base de investigación.

9. Fuentes

- Estándar HMAC (RFC 2104): <https://www.rfc-editor.org/rfc/rfc2104>
- Amazon Web Services, Signature Version 4: https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_sigv4-signing-elements.html
- Google Cloud Storage, signed URLs y llaves HMAC: <https://docs.cloud.google.com/storage/docs/access-control/signed-urls>
- GitHub, validación de webhooks: <https://docs.github.com/en/webhooks/using-webhooks/validating-webhook-deliveries>
- Slack, verificación de solicitudes: <https://api.slack.com/docs/verifying-requests-from-slack>
- Shopify, verificación de webhooks: <https://shopify.dev/docs/apps/build/webhooks/verify-deliveries>
- Zoom, verificación de webhooks: <https://developers.zoom.us/docs/api/webhooks/>